DAY 08 | POST-READ

Advanced FastAPI and Security: Recap and Beyond

What we covered today, plus ideas to stretch your understanding.

Prepared by **Ahmed** | linkedin.com/in/ahmed-al-imaad

Part A: Summary of today

Topic	What to remember
Depends()	Declare a function as a parameter dependency; FastAPI calls it and passes the result.
yield dependencies	Setup before yield, clean up after; ideal for DB sessions.
Middleware	@app.middleware("http") wraps every request; use for timing, logging, request ids.
CORS	CORSMiddleware lists which browser origins may call the API.
Authn vs authz	Who you are (401) vs what you may do (403).
Password hashing	Slow, salted hashes (bcrypt, argon2, pbkdf2). Never plain text.
JWT	header.payload.signature. Signed, readable, short-lived (exp claim).
Protected routes	OAuth2PasswordBearer + a current_user dependency that decodes the token.
PyMongo in FastAPI	Inject the collection; convert ObjectId to string for responses.

Part B: Going beyond today

1. Role based access as a dependency

```
def require_role(role: str):
    def checker(user=Depends(current_user)):
        if user["role"] != role:
            raise HTTPException(403, "Not allowed")
        return user
    return checker

@app.delete("/notes/{nid}", dependencies=[Depends(require_role("admin"))])
```

2. Overriding dependencies in tests

```
app.dependency_overrides[current_user] = lambda: {"sub": "tester", "role": "admin"}
```

Tests can skip real login or use a fake database without touching production code.

3. Secrets belong in the environment

Load SECRET_KEY and MONGO_URI from environment variables, or with pydantic-settings from a .env file that is never committed to Git.

4. Access and refresh tokens

Short-lived access tokens (15 to 30 minutes) limit damage if stolen. A longer-lived refresh token, stored more carefully, gets a new access token without logging in again.

5. Password hashing libraries

We used Python's built-in hashlib.pbkdf2_hmac so it runs anywhere. In production, popular choices are bcrypt or argon2 through libraries such as pwdlib or passlib.

6. Rate limiting

Protect /token from password guessing by limiting attempts per IP or per user. Libraries like slowapi plug into FastAPI as middleware or dependencies.

Part C: Check yourself

- What runs after the yield in a dependency, and when?
- Give two good uses for middleware.
- Why must password hashing be slow?
- Can a client read the contents of a JWT? Can it change them?
- What status code should an expired token produce?

Part D: Practice ideas for tonight

- Add an admin role that can see every user's notes, while members see only their own.
- Add a request id middleware that adds X-Request-ID to every response.
- Write tests that override current_user so you can test protected routes without logging in.

Coming up on Day 9: CRUD APIs with MongoDB, aggregation, pagination and indexes, and your first steps in JavaScript.

Otsukaresama deshita (お疲れ様でした): thank you for your hard work today